

ELITE STAR MEDICAL CLINIC

Security Awareness Training Program

Annual Workforce Training Program | 2026

Document ID:	ESMC-SAT-001
Version:	1.0
Effective:	April 25, 2026
Owner:	Privacy & Security Officer
Audience	All Workforce Members, Contractors, and Business Associates
Review Cycle:	Annual (or upon material policy/ regulatory change)

1. Program Purpose and Regulatory Basis

The Security Awareness Training (SAT) program establishes a culture of information security and HIPAA compliance across the workforce. The program ensures Staff understand their responsibilities, can recognize cybersecurity threats, and know how to respond to incidents appropriately.

This program satisfies:

- HIPAA Security Rule §164.308(a)(5) — Security Awareness & Training
- HITECH Act — Breach notification training
- NIST SP 800-50 — IT Security Awareness Program guidance
- California Civil Code §1798.82 — Data-breach notification requirements

2. Scope and Applicability

Applies to all individuals who interact with clinic information systems or protected health information (PHI):

- Employees (clinical and administrative)
- Contractors, temps, and agency workers
- Medical students, interns, and volunteers
- Business associates and vendors with system access
- Board members with system access

3. Training Curriculum and Modules

The annual training program consists of the following required modules. All modules are mandatory for general workforce members; additional role-specific training is required for IT: clinical leadership and billing staff.

MODULE	TITLE	DURATION	AUDIENCE	APPLICABILITY
Module 1	HIPAA Privacy and Security Fundamentals	60 min	All Staff	All covered Entities and workforce members
Module 2	Phishing, Social Engineering & Email Security	45 min	All Staff	All workforce members with email access
Module 3	Password management and multifactor authentication	30 min	All Staff	All system users
Module 4	Device endpoint and remote work security	30 min	All Staff	All Staff with device / remote access
Module 5	ePHI Handling& Data Classification	45 min	Clinical & Admin	Stan, who access transmit or stores PHI

Module 6	Incident Recognition and Reporting Procedures	30 min	All Staff	All workforce members
Module 7	Ransomware and Malware Awareness	30 min	All Staff	All system users
Module 8	Physical Security and Clean Desk Policy	20 min	All Staff	Are on-site will work force members
Module 9 (IT)	Privilege Access and System Administration Security	90 min	IT Only	IT administration and technical Staff
Module 10 Clinical	Telehealth and connected medical device security	45 min	Clinical Staff	Clinicians using telehealth or connect the devices

4. Training Delivery Methods

4.1 New Hire Onboarding Training

New hires must complete initial training within 30 days before receiving unescorted system access.

4.2 Annual Refresh your Training

Annual training must be completed by December 31 each year and includes updates based on:

- New threats
- Regulatory changes
- Incident trends

4.3 Event-Driven Training

Triggered by:

- Security incidents
- New threats (e.g., ransomware campaigns)
- Regulatory or policy changes
- New system or PHI access
- Repeat policy violations

4.4 Delivery formats

- Online self-paced e-learning
- Instructor-led (in-person or virtual) sessions
- Quarterly phishing simulations
- Micro-learning advisories & newsletters
- Semi-annual incident-response table-top exercises

5. Phishing Simulation Program

The clinic conducts quarterly phishing simulations to measure susceptibility and improve awareness.

5.1 Simulation Design Principles

- Healthcare-specific lures (lab results, HR alerts, IT updates)
- Gradually increasing difficulty
- Users who click links complete a 15-min remedial lesson
- Non-punitive unless repeated violations occur

5.2 Reporting Metric

- Click Rate (%)
- Report Rate (%)
- Remediation Completion Rate
- Quarterly performance comparison

6. Training Records and Tracking

The Privacy & Security Officer maintains:

- Name & role
- Modules completed
- Completion dates
- Delivery method
- Quiz/assessment scores
- Acknowledgment signatures

Records are retained for a minimum of 6 years per HIPAA and California regulations.

7. Roles and Responsibilities

- **Privacy & Security Officer (PSO):**
 - Owns program, updates curriculum, manages phishing simulations, maintains records.
- **Human Resources:**
 - Enrolls new hires, monitors completion, updates role assignments.
- **Department Managers:**
 - Ensure staff complete training on schedule; escalate non-compliance.
- **IT Department:**
 - Administers LMS, provides technical training content, runs simulations.
- **All Workforce Members:**
 - Complete required training; apply secure practices; report suspicious activity.

8. Non-Compliance & Sanctions

Consequences may include:

- Suspension of system access
- Written warnings
- HR disciplinary action
- Contractor/vendor access termination

Intentional misuse of PHI may result in immediate termination and legal reporting.

9. Program Evaluation & Continuous Improvement

Evaluated annually using:

- Completion rates
- Phishing performance metrics
- Post-training survey feedback
- Incident & near-miss analysis
- NIST/HIPAA guidance updates

Summary documented in the Annual Training Effectiveness Report

Appendix A Training Calendar Template

Quarter	Activity	Audience	Owner
Q1 (Jane-Mar)	Annual training rollout; Phishing simulation #1	All Staff	PSO/IT
Q2 (Apr-Jun)	Phishing simulation #2; tabletop exercise	All + leadership	PSO/IT
Q3 (Jul-Sep)	Phishing simulation #3 mid-year compliance check	All Staff	PSO/IT
Q4 (Oct-Dec)	Phishing simulation #4 program review & curriculum update	All Staff Leadership	PSO

Appendix B: Training Completion Attestation

I acknowledge that I have completed the required security awareness training and understand my responsibilities under the Clinic's Information Security Policies.

Name (Print)	
Job Title:	
Signature:	
Date Completed	